

YILDIZ

SİBER TEHDİT İSTİHBARATI TAKIMI

KIMSUKY

NİSAN 2025





İÇİNDEKİLER

1.Özet

2.APT Tanımı

2.1 Kullandığı Taktikler

2.2 Kullandığı Araçlar

3.APT Sınıflandırması

4.APT Tarihçesi

5.APT Grubunun Hedefleri

5.1 Hedef Aldığı Sektörler

5.2 Hedef Aldığı Teknolojiler

5.3 Hedef Aldığı Ülkeler

6.TTP Analizi

6.1 Spear Phishing Attachment – MITRE T1566.001

6.2 Command and Scripting Interpreter: Power Shell (MITRE T1059.001)

6.3 Önyükleme veya Oturum Açma Otomatik Başlatma Çalıştırma : Kayıt Defteri Çalıştırma Anahtarları / Başlangıç Klasörü (MITRE T1547.001)

6.4 Process Injection - MITRE T1055

6.5 Obfuscated Files or Information - MITRE

T1027 6.6 OTHER TTP - MITRE ATT&CK

7.Phishing Domain Adları , C2 Sunucuları, Hash (IoC)

7.1 Kimlik Avı, E-posta Temaları ve Göndericileri

8. Kimsuky APT Saldırılarının Algılanması ve Analiz

9. APT Grubuna Karşı Öneriler ve Önlemler

10. Sonuç



1.ÖZET

Kimsuky, casusluk amacıyla ağırlıklı olarak Güney Koreli düşünce kuruluşlarını, sanayiye, nükleer enerji operatörlerini ve Birleşme Bakanlığı'nı hedef alıyor. Hükümet destekli çalışan bu grup 2013 yılından beri istihbarat ve bilgi hırsızlığı konusunda profesyonel olarak aktif faaliyet gösterdiği bilinmektedir. Bu raporda yürütülen analize göre Kim hanedanlığı rejiminin devam ettirilmesi, Kore Yarımadasını Kuzey Kore liderliğinde birleştirilmesi gibi güçlü motivasyonla bilgi toplama ve finansal hırsızlık operasyonları gerçekleştirilmektedir.

Kuzey Kore medya , finans, akademisyenler ve Kuzey Kore ile bağlantısı olan kişiler olmak üzere rakiplerin nasıl düşündüğüne dair fikir edinmek için bilgi toplama operasyonları yürütmektedir. Kriz zamanlarında özellikle füze teknolojilerine erişim sağlayarak avantaj elde etmek için bilgiye erişmeyi hedeflemektedir.

2. APT TANIMI

Kimsuky bir diğer adıyla bilinen **Black Banshee** Kuzey Kore siber tehdit aktörü grubudur. İlk olarak 2013'te gözlemlenen Kimsuky, öncelikli olarak Güney Kore'ye odaklanarak ve erişimini Amerika Birleşik Devletleri ve Avrupa'ya genişleterek **hassas bilgileri** takip etmeye kararlı tehdit aktör grubudur.

2.1 Kullandığı Taktikler

Kimsuky sistemlere sızmak ve hassas bilgiler toplamak için bir dizi taktik kullanır.

Kimsuky'nin sistemlere yetkisiz erişim elde etmek için kullandığı temel yöntemlerden biri, **spearphishing e-postaları**dır. E-postalar genellikle kötü amaçlı ekler veya bağlantılar içerir. Kimsuky'nin Güney Kore'de popüler olan **Hangul Word Processor (HWP)** dosyalarını kullandığı bilinmektedir.



Diğer bir yöntemi ise **kötü amaçlı chrome uzantıları**'dır. Kurbanları meşru görünen web sitelerine çeker ve bir Chrome uzantısı yüklemelerini ister. Bu uzantı yüklendikten sonra tarayıcıdan çerezleri ve parolaları çalabilir.

Ayrıca güvenlik açıklıklarından yararlanarak bilinen güvenlik açıklıklarını istismar eder. Kötü amaçlı kod yürütmek için **Microsoft Word'deki (CVE-2017-0199)** bir güvenlik açığına istismar ettiler.

Kimsuky bir sisteme erişim sağladığında, kontrolü sürdürmek için kötü amaçlı yazılımlar dağıtır . Bu tür kötü amaçlı yazılımlardan biri **BabyShark**'tır. Ayrıca kullanıcının eylemlerini izlemek ve daha fazla bilgi toplamak için **tuş kaydediciler** ve **uzaktan kontrol** yazılımları da kullanırlar.

2.2 Kullandığı Araçlar

BabyShark kötü amaçlı yazılım, enfekte olmuş sistemlerden veri toplamak için kullanılır. Genellikle ikinci aşama yük olarak **spearphishing e-postaları** aracılığıyla iletilir .

Gold Dragon Aralık 2017'de Kore'de aynı Olimpiyat bağlantılı örgütleri hedef alan bir kimlik avı kampanyası sırasında veri toplama aracı olarak görüldü. Aracın, 2018 Pyeongchang Kış Olimpiyatları ile bağlantılı kuruluşlara yönelik operasyonlarda kullanıldığı gözlemlendi.

İkinci aşama arka kapı uygulaması olan Gold Dragon, **steganografi** kullanan, dosyasız, PowerShell tabanlı bir ilk saldırının yürütülmesinin ardından kurbanın sisteminde kalıcı bir varlık sağladı .

SWEETDROP, Kimsuky tarafından Covid-19 salgını sırasında aktif olarak kullanılan bir kötü amaçlı yazılım bırakıcıdır. Temel sistem bilgilerini toplayan ve Kimsuky'nin arka kapısı olan **"BITTERSWEET"**in indirilmesi ve yürütülmesi gibi ek aşamaları indirip yürütebilen bir C/C++ Windows uygulamasıdır .



Adı	Türü
AppleSeed	Malware / RAT
BabyShark	Malware / Infostealer
BITTERSWEET	Malware / Downloader
CSPY Downloader	Downloader
FlowerPower	Malware
Gh0st RAT	Remote Access Trojan (RAT)
Gold Dragon	Malware / Spyware
Grease	Malware / Loader
KGH SPY	Spyware
KimJonqRAT	Remote Access Trojan (RAT)
KPortScan	Network Scanning Tool
MailPassView	Password Recovery Tool
Mechanical	Malware / Unknown
Mimikatz	Credential Dumping Tool
MoonPeak	Malware / Surveillance
MyDoqs	Malware / RAT
Network Password Recovery	Password Recovery Tool
ProcDump	Memory Dump Tool
PsExec	Lateral Movement Tool
ReconShark	Reconnaissance Tool
Remote Desktop PassView	Password Recovery Tool
SHARPEXT	Browser Extension Spyware
SmallTiger	Malware / RAT



SniffPass	Network Credential Sniffer
SWEETDROP	Malware / Downloader
TODDLERSHARK	Malware / Variant of BabyShark
TRANSLATEXT	Malware / Data Exfiltration
Troll Stealer	Infostealer
VENOMBITE	Malware / Exploit Tool
WebBrowserPassView	Password Recovery Tool
xRAT	Remote Access Trojan (RAT)
Living off the Land	Teknik / Legit Aracların kötüve kullanımı

3. APT Sınıflandırılması

Kimsuky'nin tarafından istismar edilen önemli güvenlik açıklıkları:

CVE-2017-0199

V3.1: 7.8 **HIGH**

V2.0: 9.3 **HIGH**

Kimsuky, BabyShark kötü amaçlı yazılımını dağıtmak için bu güvenlik açığından yararlandı . Bu , özel olarak hazırlanmış bir dosyanın kod yürütmesine izin veren Microsoft Word'deki bir güvenlik açığıdır .

HWP Exploits

Hangul Kelime İşlemci (HWP) dosyaları Güney Kore'de yaygın olarak kullanılmaktadır . Kimsuky'nin sistemlere dropper'lar yüklemek için bilinen güvenlik açıklarını istismar eden **HWP dosyalarını** kullandığı bilinmektedir .

CVE-2015-2545

V3.1: 7.8 **HIGH**

V2.0: 9.3 **HIGH**



Bu , özel olarak hazırlanmış **EPS görüntü dosyaları aracılığıyla uzaktan kod yürütülmesine** izin veren **Microsoft Office'teki** bir güvenlik açığıdır . Kimsuky, bu güvenlik açığını kötü amaçlı kod yürütmek ve hedef sistemlere kötü amaçlı yazılım yüklemek için kullanmıştır.

CVE-2019-0604

V3.1: 9.8 **CRITICAL**

V2.0: 7.5 **HIGH**

Kimsuky, Microsoft SharePoint'teki bu güvenlik açığını keyfi kod yürütmek için kullandı . Saldırganlar, özel olarak hazırlanmış bir **SharePoint uygulama paketi** göndererek , SharePoint uygulama havuzu ve SharePoint sunucu çiftliği hesabı bağlamında keyfi kod çalıştırabilir.

4. APT Tarihçesi

Ülke: Kuzey Kore 

Sponsor: Devlet
destekli

Hedef Alan	Saldırı Türü	Amac
Hükümet ve diplomasi	Spear Phishing, RAT	Bilgi hırsızlığı
Akademik ve düşünce kuruluşları	Zararlı belge & e-posta	Politika analizleri, nükleer stratejiler
Savunma sanayi	Gelişmiş kötü yazılım	Savunma teknolojileri
Sağlık kurumları	Kimlik avı, kötü yazılım	Sağlık verisi sızdırma
Mobil kullanıcılar	Android zararlısı	Gizli iletişim takibi
Medya ve gazeteciler	Sosyal mühendislik	Algı operasyonu ve içerik takibi



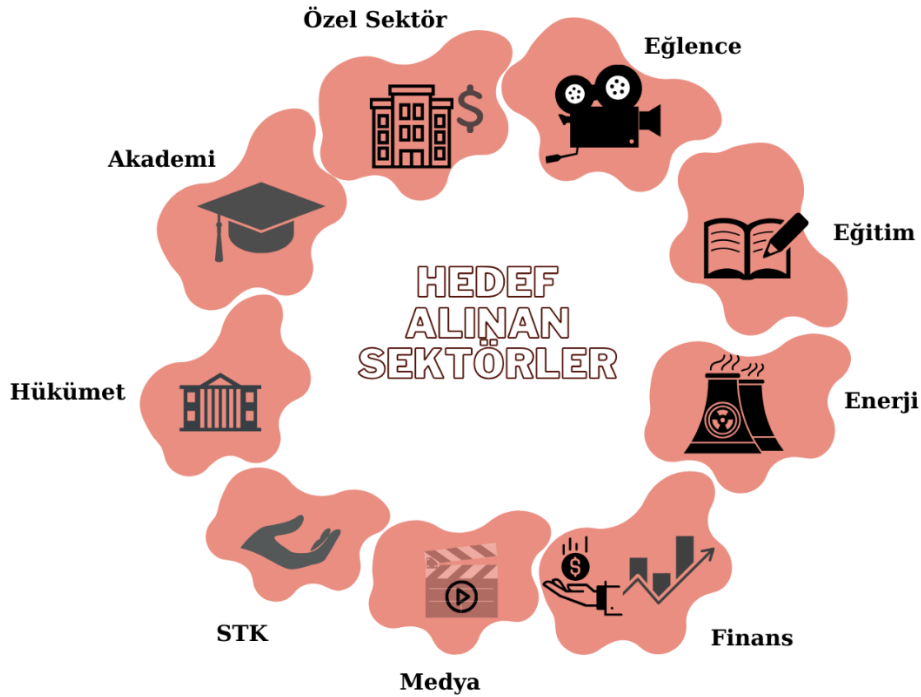
<i>Tarih</i>	<i>Operasyon / Olay Adı</i>	<i>Açıklama</i>
2013	Kimsuky Operasyonu	Güney Koreli düşünce kuruluşlarına yönelik siber casusluk kampanyası.
2014	KHNP Saldırısı	Kuzey Kore'nin, Güney Kore Nükleer Enerji Şirketi'ne (KHNP) sızarak veri çaldığı iddia edildi.
Mar 2018	Baby Coin Operasyonu	Yeni bir Kimsuky kampanyası. Kripto para sektörü
May 2018	Stolen Pencil	Akademik kurumları hedef alan bir APT kampanyası.
Oct 2018	Mystery Baby	Güney Kore'ye yönelik devam eden kampanyaların bir parçası.
Nov 2018	BabyShark Zararlısı	ABD'li nükleer güvenlik uzmanı gibi davranılarak iltalama e-postaları gönderildi.
Jan 2019	Kabar Cobra Operasyonu	Güney Kore Birleşme Bakanlığı basın mensuplarına iltalama e-postaları gönderildi.
Apr 2019	Stealth Power & Smoke Screen	Güney Koreli hedeflere yönelik çeşitli zararlı yazılım kampanyaları.
Jul 2019	Red Salt Operasyonu & Emekli Yetkililere Saldırı	Eski diplomat ve generaller hedef alındı.
Feb-Mar 2020	COVID-19 ve BM Yetkilileri	COVID-19 belgeleriyle zararlı yazılım yayma ve BM Güvenlik Konseyi üyelerini hedef alma.
Dec 2020	AppleSeed, Hisse Senedi Uygulaması	Güney Koreli hisse senedi uygulamasına zararlı yazılım enjekte edildi.
2021	TA406 Kampanyası	Kimsuky'nin kimlik avı, dolandırıcılık ve casusluk içeren üçlü saldırı modeli.
May 2021	KAERI ve Hastane Saldırıları	Atom Enerji Araştırma Enstitüsü ve büyük bir hastane hack'lendi.
Jun 2021	Zararlı Bloglar	Bloglar aracılığıyla zararlı yazılım dağıtımı.
Sep 2021	SHARPEXT Tarayıcı Uzantısı	E-posta çalan tarayıcı uzantısı geliştirildi.
2022	xRAT, GoldDragon, Covert Stalker	Açık kaynaklı RAT, C2 altyapısı ve gizli izleme kampanyası kullanıldı.
Oct 2022	Android Zararlısı	Android cihazlara yönelik gelişmiş zararlı yazılım.
2023	Çok Sayıda Kampanya	Kimlik avı, CHM/OneNote zararlısı, RDP kullanımı, sosyal mühendislik, Chrome Remote Desktop ve sahte belgelerle saldırılar.
2024	DEEP#GOSU ve TrollAgent	Sahte imzalı zararlı yazılımlar, güvenlik yazılımı kurulumu sırasında bulaşan zararlılar.



5. APT Grubunun Hedefleri

Güney Kore, Kore Yarımadası ve Amerika Birleşik Devletleri başta olmak üzere rakiplerin düşüncelerine dair fikir edinmek ve çatışmalarda üstün rol oynayabilmek adına avantaj sağlanabilecek teknolojiye erişmek için bilgi toplayan bir gruptur. Kuzey Kore devlet destekli tehdit aktörleri saldırı hedeflerine bakıldığında casusluğun birincil hedef olduğu yapılan saldırılardan anlaşılmaktadır. Ana motivasyonları rejimin devamlılığını sağlamak ve Kore yarımadasının birleşmesini sağlamaktır.

5.1 Hedeflenen Sektörler



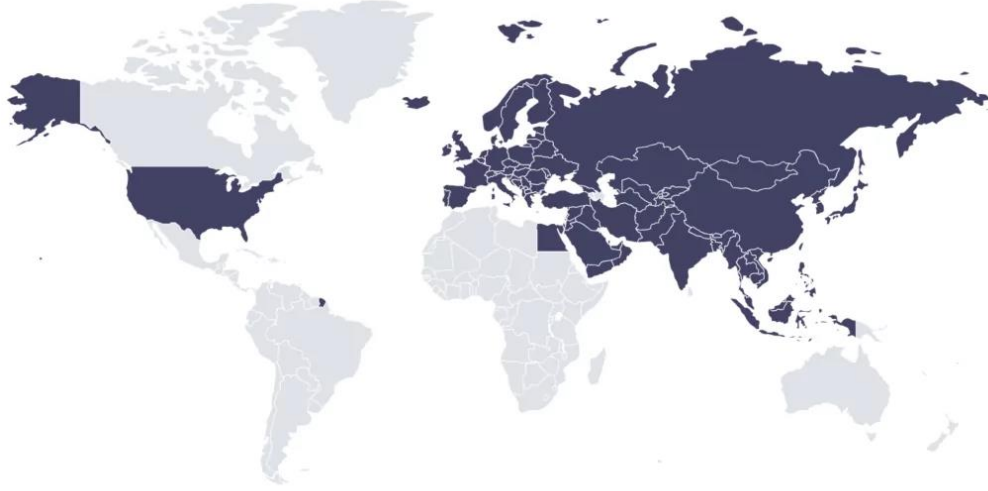
5.2 Hedeflenen Teknolojiler

Ofis Paketleri Yazılım, İşletim Sistemi, Web Uygulaması



5.3 Hedef Aldığı Ülkeler

Güney Kore, Amerika Birleşik Devletleri, Japonya, Vietnam ve Avrupa ülkeleri (özellikle NATO ile bağlantıları olanlar)



6. APT Taktikleri, Teknikleri, Prosedür (TTP) Analizi

Kuzey Koreli tehdit aktörü olan Kimsuky, bir dizi taktik, teknik ve prosedür (TTP) sergilemiştir. Kimsuky'nin nasıl çalıştığını ve kullandıkları araçları anlamak için TTP'ler bulunmaktadır.

6.1 Spear Phishing Attachment – MITRE T1566.001

Kimsuky APT, hedef sistemlere ilk erişimi elde etmek için sıklıkla kötü amaçlı bağlantılar ve eklerle hedefli kimlik avı e-postaları kullanır. Spearphishing kampanyalarında Word, Excel ve/veya HWP (Hangul Kelime İşlemcisi) belgeleri içeren e-postalar kullandı.

Kimsuky, **PHPMailer** ve **Star** gibi araçları kullanarak kimlik avı mesajları göndermek için tehlikeye atılmış altyapıyı kullandı. Takip eden saldırılar için hesapları ele geçirmeye çalıştı. Yanlış yapılandırılmış **DNS DMARC** politikalarını istismar etme gibi teknikler kullandı.



6.2 Command and Scripting Interpreter: Power Shell (MITRE T1059.001)

Invoke-Mimikatz dahil olmak üzere çeşitli PowerShell betiklerini yürütmüştür. Kimsuky, tehlikeye atılmış sistemlerde komutları yürütmek için PowerShell betiklerinden yararlanır. Bu teknik, ek yükleri indirme ve bunları diske yazmadan yürütme gibi çeşitli görevleri gerçekleştirmelerine olanak tanır, böylece tespitten kaçınır.

6.3 Önyükleme veya Oturum Açma Otomatik Başlatma Çalıştırma : Kayıt Defteri Çalıştırma Anahtarları / Başlangıç Klasörü (MITRE T1547.001)

Kimsuky, kalıcılık için başlangıç klasörüne betikler yerleştirdi ve **HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\RunOnce** register key modifiye etti.

6.4 Process Injection - MITRE T1055

Kimsuky, ayrıcalık yükseltme için çeşitli karmaşık teknikler kullanmaktadır. Bilinen zafiyetlerden ve araçlardan yararlanarak yüksek erişim elde eder. Tehlikeye atılmış sistemlerde kalıcılığını korur. Kötü amaçlı kodu **explorer.exe** 'ye enjekte etmek için Metasploit çerçevesinden **Win7Elevate** istismarının kullandı. Kullanılan kod explorer.exe'ye enjekte edildikten sonra kötü amaçlı yazılım tuş kaydediciler ve uzaktan erişim yardımcı programları gibi bir dizi casusluk aracının şifresini çözer. Bu kurbanın işletim sisteminden bağımsız olarak kötü amaçlı yazılımın kaynaklarından dinamik olarak çıkarılır. Şifresi çözülen dosya daha sonra rastgele ancak sabit kodlanmış bir ad kullanılarak diske kaydedilir ve kullanıcının geçici klasöründe saklanır. Bu, sistem yeniden başlatıldıktan sonra bile kalıcılığı garanti eder.

6.5 Obfuscated Files or Information - MITRE T1027

Kimsuky, XOR şifrelemesi ve Base64 kodlaması kullanımı da dahil olmak üzere ikili dizeleri gizledi. Kimsuky ayrıca, yürütülebilir dosya biçiminin tanınmasını önlemek için kurbanları hedefleyen DLL implantlarının ilk baytını değiştirdi.

Grup zararlı yazılımlarını gizlemek için karartma yönemi kullanıyor. Bu komut dosyalarını kodlamayı ve yükleri sıkıştırmak ve şifrelemek için paketleyiciler kullanmayı içerir ve bunların antivirüs çözümleri tarafından tespit edilmesini zorlaştırır. Komut, gizlenmiş bir Base64 dizesini bir dosyaya yansıtarak başlıyor ve ardından meşru bir Windows yardımcı programı olan **certutil** aracını kullanarak bunu çözüyor.



6.6 DİĞER TTP - MITRE ATT&CK

Domain	ID	Name	Use
Enterprise	T1071.001	Application Layer Protocol: Web Protocols	Kimsuky, C2 için HTTP GET ve POST isteklerini kullandı.
Enterprise	T1560.001	Archive Collected Data: Archive via Utility	Kimsuky, çalınan dosyaları dışarı sızdırılmadan önce arşivlemek için QuickZip 'i kullandı.
Enterprise	T1114.003	Email Collection: Email Forwarding Rule	Kimsuky, kurbanların e-posta hesaplarına otomatik yönlendirme kuralları koydu.
Enterprise	T1074.001	Data Staged: Local Data Staging	Kimsuky toplanan veri dosyalarını C:\Program Files\Common Files\System\Ole DB\ altında düzenledi.
Enterprise	T1562.004	Impair Defenses: Disable or Modify System Firewall	Kimsuky'nin sistem güvenlik duvarını devre dışı bıraktığı gözlemlendi.
Enterprise	T1219	Remote Access Software	Kimsuky, komut ve kontrol kanalı olarak değiştirilmiş bir TeamViewer istemcisi kullandı.
Enterprise	T1056.001	Input Capture: Keylogging	Kimsuky, tuş vuruşlarını kaydetmek için PowerShell tabanlı bir keylogger'ın yanı sıra MECHANICAL adlı bir araç da kullandı.
Enterprise	T1082	System Information Discovery	Kimsuky, bir komut dosyası veya "systeminfo" komutunu sürücüler, işletim sistemi türünü, işletim sistemi sürümünü ve bilgileri sıraladı
Enterprise	T1003.001	OS Credential Dumping: LSASS Memory	Kimsuky, Mimikatz ve ProcDump kullanarak kimlik bilgilerini topladı.



7. Phishing (Domains) Alan Adları ve C2 Sunucuları

Domains			
cookieanager.ne[.]l r	nidioln.ne[.]kr	naverbox.pe[.]kr	evangelia[.]edu
wud.wuaze[.]com	ned.kesuq[.]com	covd.2kool4u[.]net	owna.loveslife[.]biz
online.korea.article- com[.]eu	login.bignaver[.]com	nvtimes.onekma[.]com	webuserinfo[.]com
member.navier.pe[.]h u	nid.naver.onektx[.]com	pro-navor[.]com	Cloudnaver[.]com
read.tongilmoney[.]c om	naver[.]pw	Resetprofile[.]com	nid.naver.unicrefia[.]co m
daurn[.]lorq	Servicenidnaver[.]com	mail.unifsc[.]com	naver.com[.]de
account.daurn.pe[.]h u	member.daum.unikortv [.]com	ns.onekorea[.]me	login.daum.unikortv[.]c om
Securetymail[.]com	riaver[.]site	account.daum.unikortv[.] com	help-navers[.]com
mailsnaver[.]com	daum.unikortv[.]com	bevyndparallel.sslport[.] work	cloudmail[.]cloud
member.daum.unix [.]kr	comment.poulsen[.]wo rk	helpnaver[.]com	ionqa[.]ml
impression.poulsen[.] work	view-naver[.]com	myaccounts.qmail.krinfo [.]com	statement.poulsen[.]wo rk
view-hanmail[.]net	naver.hol[.]les	demand.poulsen[.]work	login.daum.netaccounts [.]info
dept-dr.lab.hol[.]les	sankei.sslport[.]work	read-hanmail[.]net	Daurn.pe[.]hu
sts.desk-top[.]work	net.tm[.]ro	Biqfile.pe[.]hu	hoqv.desk-top[.]work
daum.net[.]pl	Cdaum.pe[.]hu	Kooo[.]qq	Usernaver[.]com
eastsea.or[.]kr	Tiosuaking[.]com	naver.com[.]ec	myaccount.nkaac[.]net



Domains			
help.unikoreas[.]kr	naver.com[.]mx	naver.koreagov[.]com	Resultview[.]com
naver.com[.]se	naver.onegov[.]com	account.daum.unikftc[.]kr	naver.com[.]cm
member-authorize[.]com	ww-naver[.]com	nid.naver.com[.]se	naver.unibok[.]kr
vilene.desktop[.]work	csnaver[.]com	nid.naver.unibok[.]kr	amberalexander.qhtdev[.]com
Nidnaver[.]email	read-naver[.]com	Nidnaver[.]net	Cooper[.]center
dubai-1[.]com	coinone.co[.]in	nidlogin.naver.corper[.]be	amberalexander.qhtdev[.]com
naver.com[.]pl	nid.naver.corper[.]be	qloole[.]net	naver[.]cx
Naverdns[.]co	smtper[.]org	Smtper[.]cz	naver.co[.]in
login.daum.kcrct[.]ml	myetherwallet.com[.]mx	downloadman06[.]com	login.outlook.kcrct[.]ml
myetherwallet.com[.]in	loadmanager07[.]com	top.naver.onekda[.]com	com-download[.]work
com-option[.]work	com-sslnet[.]work	com-vps[.]work	com-ssl[.]work
desk-top[.]work	intemet[.]work	ip-ssl[.]work	org-vip[.]work
sslport[.]work	sslserver[.]work	ssltop[.]work	taplist[.]work
vpstop[.]work	Webmain[.]work	preview.manage.orgview[.]work	intranet.ohchr.accountprotect[.]work



Malware Adı	Açıklama	C2 URL Deseni
AppleSeed	Backdoor	http://hao.aini.pe[.]hu/init/image?i=pinq&u=8dc1078f1639d34c&p=wait.. http://mernberinfo[.]tech/wp-data/?m=dunan&p=de3f6e263724&v=win6.1.0-sp1-x64 http://eastsea.or[.]kr/?m=a&p1=00000009&p2=Win6.1.7601x64-Spy-v2370390
FlowerPower	Powershell based profiling tool	http://dongkui.atwebpages[.]com/venus02/venus03/venus03.ps1 http://attachchosun.atwebpages[.]com/leess1982/leess1982.ps1
Gold Dragon	Backdoor	http://portable.epizv[.]com/img/png/download.php?filename=images01 http://foxonline123.atwebpages[.]com/home/jpg/download.php?filename=flower03
BabyShark	VBS-based backdoor and reconnaissance tool	http://nhpurumy.mireene[.]com/theme/basic/skin/member/basic/upload/download.php?param=res2.txt http://jmable.mireene[.]com/shop/kcp/js/com/expres.php?op=2



KGH malware suite	Different components in the KGH malware suite	http://csv.posadadesantiago[.]com/home? http://csv.posadadesantiago[.]com/home/up.php?id=[Machine_name]
CSPY Downloader	Downloader	http://wave.posadadesantiago[.]com/home/dwn.php?van=10860 http://wave.posadadesantiago[.]com/home/dwn.php?van=101 http://wave.posadadesantiago[.]com/home/dwn.php?van=102
KGH Backdoor winload.x	Backdoor and Keylogger component, VBS downloader	http://csv.posadadesantiago[.]com/home?act=news&id=[Machine_name] http://csv.posadadesantiago[.]com/home?id= http://csv.posadadesantiago[.]com/home?id=[Machine_name]&act=tre&ver=x64 http://csv.posadadesantiago[.]com/home? http://csv.posadadesantiago[.]com/home? http://csv.posadadesantiago[.]com/home?id=[Machine_name]&act=pws&ver=x64
PM Abe draft letter on UN NK 20200130.d	Phishing document	http://myaccounts.posadadesantiago[.]com/test/Update.php?wShell=201



IP Adres	Domain Adı	Kimsuky Aktivitesi
173.205.125.124	csv.posadadesantiago[.]com	KGH Backdoor
	wave.posadadesantiago[.]com	CSPY Downloader
	myaccounts.posadadesantiago[.]com	Malicious Phishing Document
	www.eventosatitlan[.]com	Baby Shark / Autumn Aperture Campaign



HASH TABLOSU

0B5DB31E47B0DCCFDEC46E74C0E70C6A1684768DBACC9EACBB4FD2EF851994C7

15D53BB839E00405A34A8B690EC181F5555FC4F891B8248AE7FA72BAD28315A9

1617587CCDF5B0344089559ECF8FE7D39F6E07A6A64F74F2B44BFA2C8CB67983

1B75F70C226C9ADA8E79C3FDD987277B0199928800C51E5A1E55FF01246701DB

2360A69E5FD7217E977123C81D3DBB60BF4763A9DAE6949BC1900234F7762DF1

2546D239A262C24A6F8EA01D890CBC459A22DB79B379B6EC3B24FBB56EFB5381

3C8DBFCBB4FCCBAF924F9A650A04CB4715F4A58D51EF49CC75BFCEFOAC258A3E

3EA2EAD8F3CEC030906DCBFFE3EFD5C5D77D5D375D4A54CCA03BFE8A6CB59940

46A5D54C264152CE915792AF31C75824A558AF7D7340D78B34E146D8C6249E79

479038EB12ED07893EE0DCC04FBDCF182489BBB271F5A4F90F83874881A80CE3

492A643BD1EFDACA4CA125ADE1B606E7BBF00E995AC9115AC84D1C4C59CB66DD

5009C7D1590C1F8C05827122172583DDF924C53B55A46826ABF66DA46725505A

5C907B722C53A5BE256DC5F96B755BC9E0B032CC30973A52D984D4174BACE456

5E40D106977017B1ED235419B1E59FF090E1F43AC57DA1BB5D80D66AE53B1DF8

60666CACDD6806ED05771F32EAA719E3EFD2F4DB55F28A447D383C3EAC1DC72E

63FB47C3B4693409EBADF8A5179141AF5CF45A46D1E98E5F763CA0D7D64FB17C

689CFAA9319F3F7529A31472ECF6B2E0CA6891B736DE009E0B6C2EBAC958CC94

69C917EA96DB28DBD5B67073CA0AAC234D25651A849171B45F20979EAF05A1C



7.1 Kimlik Avı E-posta Temaları ve Göndericileri

Sender domains: inbox[.]ru, mail[.]ru, internet[.]ru, list[.]ru

İfadeler örneğin: “Payment deadline,” “Payment due date,” “National Tax Service,” and “Blog post restriction information”.



8. KIMSUKY APT SALDIRILARININ ALGILANMASI VE ANALİZİ

```
rule APT_KimSuky_bckdr_dll {
  meta:
    description = "Armadillo packed DLL used in Kimsuky campaign"
    author = "Christiaan Beek - McAfee Advanced Threat Research"
    date = "2018-02-09"
    rule_version = "v1"
    malware_type = "backdoor"
    malware_family = "Backdoor:W32/Kimsuky"
    actor_type = "Apt"
    actor_group = "Unknown"
    reference = "https://securelist.com/the-kimsuky-operation-a-north-korean-apt/57915/"
    hash = "afe4237ff1a3415072d2e1c2c8954b013471491c6afdce3f04d2f77e91b0b688"
    strings:
      $x1 = "taskmgr.exe Execute Ok!!!" fullword ascii
      $x2 = "taskmgr.exe Execute Err!!!" fullword ascii
      $x3 = "kkk.exe Executing!!!" fullword ascii
      $s4 = "ShellExecuteA Ok!!!" fullword ascii
      $s5 = "ShellExecuteA Err!!!" fullword ascii
      $s6 = "Manage.dll" fullword ascii
      $s7 = "%s_%s.txt" fullword ascii
      $s8 = "kkk.exe Copy Ok!" fullword ascii

      $op0 = { be 40 e9 00 10 8d bd 3c ff ff ff 83 c4 48 f3 a5 }
      $op1 = { 8b ce 33 c0 8b d1 8d bc 24 34 02 00 00 c1 e9
02 } $op2 = { be dc e9 00 10 8d bd 1c ff ff ff f3 a5 8d bd
1c } condition:
      ( uint16(0) == 0x5a4d and filesize < 200KB and
      ( 1 of ($x*) and 4 of them ) and all of ($op*)) or ( all of
} them )
```



9. ÖNERİLER ve ÖNLEMLER

Kimsuky'nin **spear-phishing** 'e olan güveni göz önüne alındığında, e-posta güvenliğini artırmak kritik bir ilk adımdır. Kuruluşlar, kötü amaçlı ekleri ve bağlantıları tespit edip engelleyebilen gelişmiş e-posta filtreleme çözümleri uygulamalıdır. Çalışanları phishing girişimlerini tanımaları için eğitmek de aynı derecede önemlidir. Düzenli phishing simülasyonları bu eğitimi güçlendirmeye ve başarılı saldırı olasılığını azaltmaya yardımcı olabilir.

Ağ segmentasyonu, saldırganların bir organizasyon içindeki yanal hareketini sınırlar. Ağı izole segmentlere bölerek, organizasyonlar olası ihlalleri sınırlayabilir ve hassas verileri koruyabilir. Sürekli ağ izleme de önemlidir. Şüpheli aktiviteler hakkında gerçek zamanlı uyarılar sağlayan araçlar, saldırıları hızlı bir şekilde tespit etmeye ve yanıtlamaya yardımcı olabilir. Sıra dışı IP adresleri ve trafik kalıpları için izleme, Kimsuky'nin operasyonlarına karşı özellikle etkili olabilir.

Yazılımı güncel tutmak, Kimsuky dahil olmak üzere herhangi bir siber tehdide karşı temel bir savunma stratejisidir. İşletim sistemlerine, uygulamalara ve güvenlik yazılımlarına düzenli olarak yamalar uygulamak, Kimsuky'nin istismar edebileceği güvenlik açıklarını kapatabilir. Otomatik yama yönetimi çözümleri, güncellemelerin tüm sistemlerde derhal uygulanmasını sağlamaya yardımcı olabilir.

Çok Faktörlü Kimlik Doğrulamayı (MFA) uygulayın; Mümkün olan her yerde, özellikle kritik sistemler ve veriler için MFA kullanın. Bu, parolalar tehlikeye girse bile ek bir güvenlik katmanı ekler.

10. SONUÇ

Bu belge TLP:AMBER olarak işaretlenmiştir. Kaynaklar, bilgilerin etkin bir şekilde harekete geçilmesi için desteğe ihtiyaç duyması ancak ilgili kuruluşların dışında paylaşıldığında gizlilik, itibar veya operasyonlar açısından risk taşıması durumu söz konusudur.

YILDIZ

SİBER TEHDİT İSTİHBARATI TAKIMI

NİSAN 2025

